Relazione 1: titolo da inserire

Nome e cognome

18 ottobre 2026

Indice

1 Introduzione **2**

2 Primo punto: Phishing e AUR **2**

2.1 Il phishing e la compromissione dell'account 2

2.2 Dalla pubblicazione malevola all'esecuzione nel browser 3

3 Secondo punto: titolo da inserire **4**

4 Conclusioni **4**

1 Introduzione

Hello World!

2 Primo punto: Phishing e AUR

La compromissione dell'account è iniziata con un'e-mail di phishing proveniente dall'indirizzo support@npmjs.help, associato ad un dominio registrato appena tre giorni prima dell'attacco e ad un server localizzato nei Paesi Bassi.

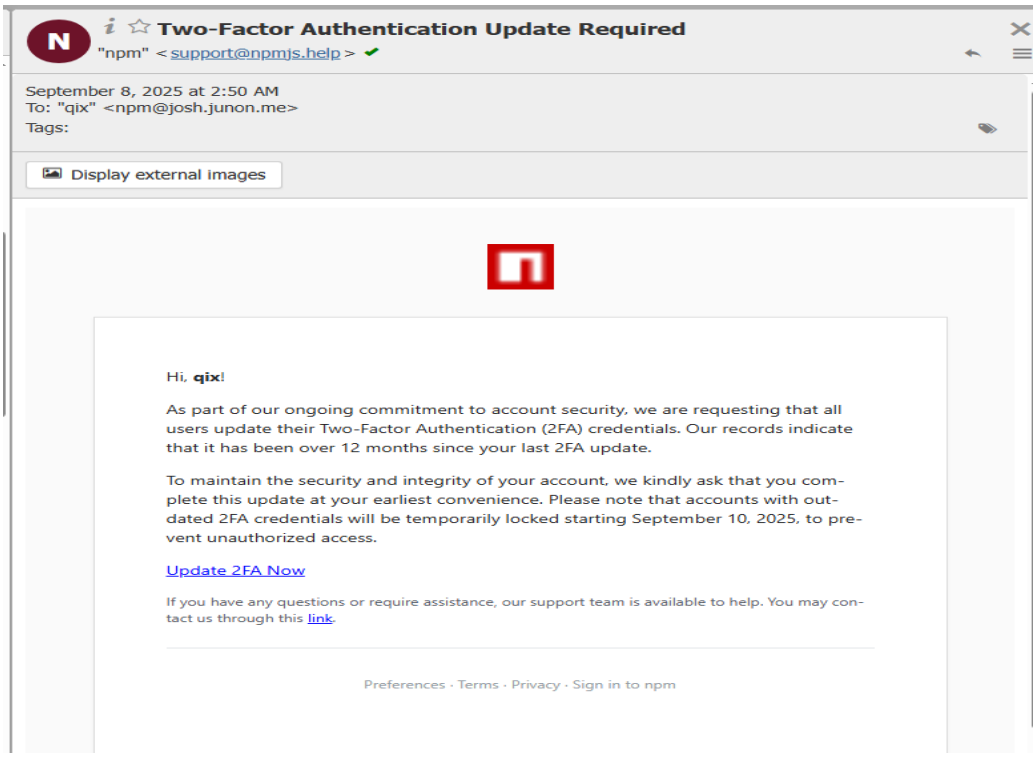


Figura 1: Mail di phishing ricevuta dall'utente.
Fonte: [**https://www.aikido.dev/blog/npm-debug-and-chalk-packages-compromised?**]

2.1 Il phishing e la compromissione dell'account

Dal testo della mail si può notare subito un dettaglio importante: entro 2 giorni l'account verrà sospeso se non si effettua il login, un chiaro tentativo di creare urgenza e pressione psicologica sull'utente. Qualche ora dopo, più precisamente alle 13:16 UTC, i sistemi di Aikido, un'azienda specializzata in cybersecurity, hanno notato che l'account di josh stava pubblicando pacchetti con codice apparentemente malevolo, permettendo in seguito di capire che era stato compromesso. Poche ore dopo l'inserimento delle proprie credenziali dal link della mail, lo stesso utente ha dichiarato di aver perso l'accesso al proprio account a seguito dell'attacco di phishing. L'e-mail particolarmente credibile e l'aver passato una settimana stressante avevano ridotto la sua attenzione, esponendolo così agli attacchi. Inoltre, Josh ha dichiarato di aver cliccato direttamente sul link presente nell'e-mail perchè stava utilizzando lo smartphone, anziché accedere direttamente al sito ufficiale di npm

come era solito fare. Tutti i pacchetti compromessi contenevano codice javascript che intercettava richieste e risposte di rete e interazioni con i wallet. Quando veniva trovato un indirizzo di un wallet, il codice lo sostituiva con un indirizzo controllato dall'attaccante per poter reindirizzare i fondi verso il proprio wallet. Per rendere più difficile la comprensione del codice malevolo, l'attaccante ha utilizzato tecniche di offuscamento del codice come l'uso di variabili con codici come per esempio la variabile 0x112fa8.



Figura 2: estratto del codice malevolo presente nei pacchetti compromessi
Fonte: [**https://www.aikido.dev/blog/npm-debug-and-chalk-packages-compromised?**]

Per portare a termine l'attacco non era necessario compromettere l'intero registro npm, è stato infatti sufficiente compromettere l'account di un publisher e sfruttarne i permessi per distribuire versioni malevole dei pacchetti per raggiungere l'obiettivo desiderato.

2.2 Dalla pubblicazione malevola all'esecuzione nel browser

A seguito dell'attacco di phishing e della compromissione dell'account, l'attaccante ha pubblicato diverse versioni malevole dei pacchetti gestiti dal manutentore. Tra queste era presente debug@4.4.2 che aveva le stesse caratteristiche della versione originale ma contenente il codice malevolo. L'attacco aveva un'ampia superficie di esposizione: secondo Aikido, i 18 pacchetti inizialmente compromessi avevano oltre 2 miliardi di download settimanali. Il codice poteva raggiungere le applicazioni attraverso le dipendenze delle librerie. Infatti, quando uno sviluppatore installava o aggiornava un pacchetto nel suo progetto, poteva anche scaricare una versione compromessa come debug@4.4.2 sia direttamente che come dipendenza di un'altra libreria. Durante la fase di build, eseguita localmente oppure attraverso processi automatizzati di integrazione e distribuzione continua (CI/CD) come per esempio il build automatico a seguito di un push, il codice malevolo poteva essere

incorporato nel bundle, ovvero l'insieme di file contenenti il codice e le dipendenze necessarie all'applicazione. Una volta distribuita l'applicazione, il codice poteva essere eseguito nei browser degli utenti finali, interferendo con eventuali operazioni relative ai wallet di criptovalute. Secondo l'advisory ufficiale di debug presente su github, il comportamento malevolo documentato riguardava esclusivamente gli ambienti browser, mentre le applicazioni eseguite su server o da riga di comando (CLI) non erano interessate da questo specifico attacco.

3 Secondo punto: titolo da inserire

4 Conclusioni